

CISSP Printable Practice Exam 19 - Domain 3 - Security Architecture and Engineering

Practice Exam 03 - Domain 3

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-040)

Scenario: A payroll platform must prevent users from directly changing salary records. All changes must use approved procedures, preserve an audit trail, and be independently reconciled against authorized requests.

Which formal security model MOST directly supports this design?

- A. Bell-LaPadula, because its primary objective is to prevent disclosure across classification levels
- B. Brewer-Nash, because it dynamically separates access to competing organizations' data
- C. Clark-Wilson, because it protects integrity through well-formed transactions and separation of duties
- D. Biba, because it requires every business transaction to be approved by two named users

Question 2 (CISSP3-041)

Scenario: A defense analytics system processes restricted and public workloads on the same platform. Architects require that changes in restricted processing must not alter outputs or observable behavior available to public users.

Which security-model concept BEST expresses this requirement?

- A. Noninterference
- B. Aggregation
- C. Least functionality
- D. Open design

Question 3 (CISSP3-042)

Scenario: A warehouse kiosk needs to run one inventory application. The proposed build includes a general-purpose desktop environment, multiple unused services, local development tools, and permanent administrator access for operators.

Which redesign BEST follows the principles of keeping security simple and minimizing functionality?

- A. Retain the full desktop build and rely on annual vulnerability scans to identify excess services.
- B. Keep development tools installed but hide their shortcuts from kiosk users.
- C. Allow operators to retain administrator rights so they can resolve application failures quickly.
- D. Use a minimal locked-down image that runs only required services and separates maintenance privileges from routine use.

Question 4 (CISSP3-043)

Scenario: A lender wants managed laptops to prove that approved firmware and boot components loaded before the laptops receive access to a sensitive application. The evidence must be resistant to software-only tampering.

Which capability is the MOST appropriate foundation for this requirement?

- A. Full-disk encryption using a password entered after the operating system starts

- B. Trusted platform module measurements and remote attestation tied to the boot sequence
- C. Application logging stored in a writable local directory
- D. A network inventory record containing the laptop model and assigned user

Question 5 (CISSP3-044)

Scenario: An emergency coordination system has two approved requirements: sensitive plans must remain unreadable if storage media are removed, and dispatch functions must continue after the loss of one processing node.

Which TWO controls MOST directly implement the stated requirements? Select 2 of the 5 options below.

- A. Role-based access restrictions for users viewing plans on an operating system
- B. Encryption of stored plans with protected key management
- C. Daily backups stored on the same processing node as the dispatch service
- D. Physical access controls around the primary equipment room
- E. Redundant processing nodes with tested failover

Question 6 (CISSP3-045)

Scenario: Field inspectors use a desktop client that downloads an entire regulated customer database to each laptop, although an inspector needs only assigned records for one day of offline work. Several laptops have recently been lost.

Which architectural change BEST reduces the client-side exposure?

- A. Require stronger user authentication but retain the entire unencrypted database on every laptop.
- B. Increase synchronization frequency while keeping every customer record on each laptop.
- C. Move the cache to a separate local partition but allow the application to store it unencrypted.
- D. Provide only assigned records, encrypt protected local storage, and remove cached data when the offline need ends.

Question 7 (CISSP3-046)

Scenario: A software company creates reusable virtual-machine images for an infrastructure cloud. A review finds static service credentials, deployment tokens, and private keys embedded in the images before they are copied into several accounts.

What is the BEST architectural remediation?

- A. Encrypt each image with one shared key and leave the embedded credentials unchanged.
- B. Build credential-free images, scan them before promotion, and obtain short-lived secrets from an authorized service at deployment time.
- C. Restrict image names to administrators while retaining the same embedded keys across accounts.
- D. Rotate the embedded credentials more frequently while continuing to place them in every shared image.

Question 8 (CISSP3-047)

Scenario: A workforce analytics database blocks direct access to individual salaries but allows users to run unlimited aggregate queries. Analysts can vary one filter at a time and subtract results to infer a specific employee's salary.

Which control strategy BEST addresses the vulnerability?

- A. Enforce minimum result-set sizes, restrict overlapping queries, and monitor patterns that can reveal individual values.
- B. Mask displayed averages to fewer decimal places but continue allowing overlapping result sets.
- C. Permit aggregate queries only during business hours without limiting query combinations.
- D. Allow unrestricted aggregates but require users to acknowledge a confidentiality notice once per year.

Question 9 (CISSP3-048)

Scenario: A chemical processing plant proposes placing its safety instrumented system on the same controllers, administrative workstations, and update process as the basic production control system to reduce cost.

Which security architecture recommendation is MOST appropriate?

- A. Place the shared production and safety controllers in a restricted cabinet while retaining common software and administration.
- B. Use the same administrator account so emergency maintenance remains simple.
- C. Maintain justified independence for safety functions, with controlled interfaces and separate failure and compromise paths.
- D. Connect both systems directly to business applications to simplify status reporting.

Question 10 (CISSP3-049)

Scenario: A research cloud will host highly sensitive analysis beside lower-trust workloads. Some tenants request direct hardware-device passthrough for performance, and management is concerned about isolation failure and residual exposure.

Which TWO controls BEST address the stated architectural risks? Select 2 of the 5 options below.

- A. Place the most sensitive workloads on dedicated hosts or equivalently strong isolation boundaries based on risk.
- B. Use one privileged host account for all tenant support personnel.
- C. Allow unrestricted device passthrough whenever a workload requests higher performance.
- D. Limit hardware passthrough to approved cases and enforce input-output memory isolation supported by the platform.
- E. Retain previous tenants' memory snapshots to accelerate future troubleshooting.

Question 11 (CISSP3-050)

Assuming a sound symmetric algorithm with no shortcut attack, which change MOST directly increases resistance to brute-force key search?

- A. Encoding the ciphertext in a different printable format
- B. Increasing the effective key length while maintaining secure key generation
- C. Renaming the algorithm in system documentation
- D. Dividing the same ciphertext into smaller files

Question 12 (CISSP3-051)

Scenario: A clinical device stores records that must remain confidential and must be rejected if an attacker alters their encrypted representation. The design team can use a supported authenticated-encryption construction.

Which approach BEST satisfies both requirements?

- A. Encrypt the records without an integrity mechanism and rely on file timestamps.
- B. Hash the plaintext and store both the plaintext and hash together without a secret key.
- C. Encode the records before storage and restrict knowledge of the encoding format.
- D. Use authenticated encryption with correctly managed keys and unique nonces as required by the construction.

Question 13 (CISSP3-052)

Scenario: A consulting firm wants business records to remain recoverable when an employee leaves. A proposal would escrow both employees' data-encryption private keys and their private digital-signature keys with the same recovery team.

What is the BEST security-architecture recommendation?

- A. Escrow all private keys together because encryption and signing serve the same security objective.
- B. Discard every encryption key at employee departure and rely on retained ciphertext for recovery.
- C. Provide controlled recovery for encryption keys when required, but do not escrow personal signing keys in a way that permits others to impersonate the signer.
- D. Publish signing private keys after employee departure so reviewers can verify archived signatures.

Question 14 (CISSP3-053)

Scenario: An examiner studies a large body of ciphertext from a simple substitution scheme and compares recurring symbols and symbol groups with expected patterns in the underlying language.

Which attack method is the examiner using?

- A. Frequency analysis
- B. Brute-force key search
- C. Side-channel analysis
- D. Chosen-ciphertext analysis

Question 15 (CISSP3-054)

Scenario: A telemetry platform uses an authenticated-encryption algorithm whose security requires a nonce never to repeat under the same key. Devices currently reset a local counter after every reboot while retaining the same encryption key.

Which redesign BEST addresses the vulnerability?

- A. Keep the rebooting counter but increase the length of the plaintext messages.
- B. Use a nonce-generation scheme that guarantees uniqueness for the key, preserves state safely across reboots, or rotates the key before reuse can occur.
- C. Reuse a prior nonce only for messages classified as low sensitivity.
- D. Encode each repeated nonce before sending it with the ciphertext.

Question 16 (CISSP3-055)

Scenario: A company plans to place a network equipment room below restrooms and beside a domestic-water riser. The room contains critical switching equipment and has no floor-level leak detection.

Which design response is MOST appropriate before construction approval?

- A. Use water-resistant equipment enclosures while leaving the utility source and

drainage design unassessed.

B. Raise the equipment racks but omit leak detection and an emergency water-shutoff procedure.

C. Relocate the room or reroute water sources where feasible, then add leak detection, drainage, and protected equipment placement based on residual risk.

D. Move the critical switches higher in the same room without changing the water source or drainage path.

Question 17 (CISSP3-056)

Scenario: A distribution center has perimeter cameras, but nighttime glare obscures faces, several fence corners are outside coverage, and recorded alerts are rarely reviewed until days later.

Which improvement BEST addresses the combined weaknesses?

A. Redesign camera placement and lighting to remove blind spots and glare, then integrate alert monitoring, retention, and response procedures.

B. Increase recording resolution while preserving blind spots and the existing lighting configuration.

C. Retain footage longer but continue reviewing alerts only after unrelated incidents occur.

D. Add warning signs and increase guard patrol frequency while leaving the camera blind spots and lighting problems unchanged.

Question 18 (CISSP3-057)

Scenario: A media archive receives equipment and supplies through a loading dock that opens into the same corridor used to enter restricted storage rooms. Deliveries are often left unattended before employees claim them.

Which TWO changes BEST reduce the loading-area risk? Select 2 of the 5 options below.

A. Allow delivery drivers to place shipments directly inside restricted storage rooms during busy periods.

B. Use the loading dock as an alternate employee entrance whenever the lobby is crowded.

C. Separate the receiving zone from restricted areas with controlled doors and defined movement paths.

D. Remove delivery records after packages are claimed to reduce administrative storage.

E. Verify, inspect, log, and secure deliveries until an authorized recipient accepts them.

Question 19 (CISSP3-058)

Scenario: During an access review, a laboratory cannot account for a master key that opens several sensitive rooms. The key has no unique marking, and the sign-out sheet does not show who last held it.

What is the BEST response?

A. Issue additional copies so authorized staff are less likely to borrow the missing key.

B. Wait for evidence of unauthorized entry before changing locks or procedures.

C. Update the sign-out sheet but assume the missing key is still inside the facility.

D. Assess affected doors, rekey or replace compromised cylinders as risk requires, and implement uniquely tracked key custody.

Question 20 (CISSP3-059)

Scenario: A regional office is moving servers and backup media to a new facility. A general moving company will transport equipment, and the new room's access controls and environmental monitoring have not yet been acceptance-tested.

Which relocation plan BEST protects the systems throughout the lifecycle transition?

- A. Ship all equipment immediately and validate the new room after production resumes.
- B. Inventory and seal assets, maintain documented custody with authorized transport, and verify new-site physical and environmental controls before installation.
- C. Allow the mover to create the asset list after delivery so the organization does not duplicate effort.
- D. Record serial numbers but use standard transport without sealed packaging or documented custody handoffs.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-040) - Correct: C

Clark-Wilson protects commercial data integrity through constrained data items, authorized transformation procedures, auditing, and separation of duties. Bell-LaPadula focuses on confidentiality, while Brewer-Nash addresses conflicts of interest. Biba is an integrity model, but it does not specifically define the well-formed transaction and certification mechanisms described here.

Question 2 (CISSP3-041) - Correct: A

Noninterference requires actions at a higher security level not to affect what lower-level users can observe, reducing unintended information flow. Aggregation concerns the sensitivity created by combining data. Least functionality reduces unnecessary features, and open design avoids relying on design secrecy; neither directly states the required flow property.

Question 3 (CISSP3-042) - Correct: D

A minimal locked-down image removes unnecessary code and services while separating privileged maintenance from normal operation, directly reducing attack surface and complexity. Scanning a broad build does not eliminate its exposure. Hidden tools remain installed, and permanent administrator access increases the impact of misuse or compromise.

Question 4 (CISSP3-043) - Correct: B

A trusted platform module can protect boot measurements and support attestation so a relying service can evaluate platform state against an approved baseline. Full-disk encryption protects stored data but does not by itself prove the boot chain. Writable logs and inventory records are not hardware-rooted evidence of loaded components.

Question 5 (CISSP3-044) - Correct: B, E

Storage encryption with protected keys directly addresses media confidentiality, while redundant nodes with tested failover address the stated single-node availability requirement. User access restrictions and equipment-room controls do not protect removed media cryptographically. A backup on the failed node cannot maintain dispatch processing after that node is lost.

Question 6 (CISSP3-045) - Correct: D

Limiting downloads to assigned records applies data minimization, while protected local storage and time-bound removal reduce the consequence of device loss. Renaming a directory is obscurity. More frequent synchronization does not reduce the local dataset, and an unencrypted partition offers no meaningful confidentiality improvement.

Question 7 (CISSP3-046) - Correct: B

Credential-free images prevent secrets from propagating with every copy, while controlled scanning and short-lived deployment-time retrieval reduce persistence and scope. Encrypting an image does not solve credential reuse after launch. Restricted names do not protect image contents, and frequent rotation still distributes each new secret across every image copy.

Question 8 (CISSP3-047) - Correct: A

Minimum group sizes, controls on closely overlapping queries, and pattern monitoring make differencing and inference attacks more difficult. Rounding can still leave exploitable differences, and limiting query hours does not restrict revealing combinations. An acknowledgment is an administrative measure that does not prevent inference.

Question 9 (CISSP3-048) - Correct: C

Independent safety functions with controlled interfaces reduce common-mode failures and help preserve the safety system if production controls are compromised. Screen colors provide no isolation. Shared administration increases common dependency, and direct business connectivity expands attack paths into both environments.

Question 10 (CISSP3-049) - Correct: A, D

Dedicated or comparably strong boundaries reduce co-residency risk for highly sensitive workloads, while controlled passthrough with input-output memory isolation limits device access to host memory. Shared privileged accounts weaken accountability. Unrestricted passthrough expands exposure, and retaining tenant memory can disclose residual sensitive data.

Question 11 (CISSP3-050) - Correct: B

A larger effective key space increases the number of candidate keys an attacker must test, assuming the algorithm and key generation remain sound. Re-encoding or splitting ciphertext does not change the cryptographic work factor. Renaming an algorithm has no technical effect.

Question 12 (CISSP3-051) - Correct: D

Authenticated encryption provides confidentiality and verifies ciphertext integrity when keys and nonces are managed according to the construction. Encryption alone may not detect malicious modification. An unkeyed hash stored with plaintext can be replaced, and encoding offers neither cryptographic confidentiality nor integrity.

Question 13 (CISSP3-052) - Correct: C

Business recovery may justify controlled escrow or recovery of encryption keys, but access to a person's signing private key could enable impersonation and undermine accountability. Encryption and signing have different objectives. Destroying needed decryption keys defeats recovery, while publishing a signing private key destroys its secrecy and trustworthiness.

Question 14 (CISSP3-053) - Correct: A

Frequency analysis uses the statistical occurrence of symbols or groups to infer plaintext structure, especially against simple substitution schemes. Brute force tests candidate keys. Side-channel analysis exploits implementation leakage, and chosen-ciphertext analysis relies on access to decryption behavior for selected ciphertexts.

Question 15 (CISSP3-054) - Correct: B

The design must preserve nonce uniqueness for each key across device restarts or change the key before a nonce can repeat. Message length does not repair nonce reuse. Sensitivity labels do not change the algorithm's security requirements, and encoding a repeated nonce does not make it cryptographically unique.

Question 16 (CISSP3-055) - Correct: C

Avoiding or rerouting the hazard is strongest; leak detection, drainage, and protected equipment placement then reduce residual exposure. Enclosures or elevated racks alone leave detection, shutoff, and drainage gaps. Raising only the switches reduces one exposure but leaves the underlying facility hazard largely unchanged.

Question 17 (CISSP3-056) - Correct: A

Effective surveillance requires usable images, complete risk-based coverage, timely monitoring, appropriate retention, and a response process. Resolution alone cannot capture an area outside the camera view or correct severe glare. Longer retention improves evidence

availability but not detection, while warning signs cannot replace the perimeter and surveillance controls.

Question 18 (CISSP3-057) - Correct: C, E

A controlled receiving boundary prevents the dock from becoming a direct path into restricted areas, while verification, inspection, logging, and secure holding preserve accountability for deliveries. Direct driver access and use as an informal employee entrance bypass zoning. Removing delivery records weakens traceability.

Question 19 (CISSP3-058) - Correct: D

A missing master key creates an unresolved access path, so affected locks must be evaluated and changed according to risk while stronger issuance and custody records prevent recurrence. More copies increase exposure. Waiting leaves sensitive rooms vulnerable, and paperwork alone cannot neutralize a key that may be outside organizational control.

Question 20 (CISSP3-059) - Correct: B

A verified inventory, tamper-evident protection, controlled custody, authorized transport, and pre-installation acceptance testing preserve accountability and ensure the destination is ready. Shipping before validation risks damage or exposure. Delegating the inventory weakens organizational control, while serial numbers without sealed transport and recorded custody do not adequately protect the move.